

Email injection

Уязвимость и защита

Коровкин Никита Михайлович Кулябов Д. С.

Российский университет дружбы народов, Москва, Россия

Информация

- Коровкин Никита Михайлович
- Студент 2 курса
- Российский университет дружбы народов
- 1132246835@pfur.ru

Вводная часть

- Повсеместное использование электронной почты
- Трансформация векторов атак
- Репутационные и инфраструктурные риски
- Недостатки автоматизации разработки

Объектом исследования является процесс программной обработки и валидации пользовательского ввода в веб-приложениях, взаимодействующих с почтовыми сервисами. Предметом исследования выступает уязвимость «инъекция E-mail», возникающая вследствие отсутствия фильтрации управляющих символов в протоколе SMTP.

Целью работы является изучение механизмов эксплуатации уязвимости Email Injection и разработка практических рекомендаций по обеспечению безопасности почтовых сервисов. В задачи исследования входит анализ структуры MIME-сообщений, демонстрация векторов CRLF-инъекций и обоснование выбора надежных программных методов фильтрации пользовательского ввода.

В качестве материалов исследования были использованы международные стандарты и спецификации протоколов передачи почты (RFC 5322, RFC 2822), рекомендации консорциума OWASP по защите веб-приложений, а также техническая документация современных программных библиотек для работы с SMTP (Python и Node.js).

Основными методами работы послужили теоретический анализ механизмов обработки CRLF-последовательностей, метод сравнительного анализа уязвимых и защищенных фрагментов программного кода, а также моделирование сценариев эксплуатации инъекций для оценки рисков информационной безопасности.

- Определение: Уязвимость, при которой невалидированные данные пользователя используются сервером для формирования почтовых сообщений.
- Где встречается: Формы обратной связи, подписки на рассылки, запросы на сброс пароля.
- Цель атакующего: Модификация структуры письма, добавление скрытых получателей или подмена контента.

- Структура письма: Состоит из заголовков (To, From, Subject) и тела сообщения, разделенных пустой строкой.
- Разделитель CRLF: Ключевой элемент синтаксиса SMTP - символы

"\r \n

" (Carriage Return + Line Feed).

- Суть уязвимости: Если приложение не фильтрует

"\r \n"

, злоумышленник может внедрить эти символы и заставить сервер интерпретировать последующий текст как новые заголовки.

BCC Injection (Скрытая копия)

Ввод: `"user@example.com\r\nBcc: spam-target@mail.com"`

Результат: Использование доверенного сервера для массовой рассылки спама. Body Injection (Инъекция в тело)

Ввод `"Subject\r\n\r\n - Фишинговое сообщение"`

Результат - Двойной перенос строки завершает блок заголовков и позволяет полностью подменить текст письма.

Прямая вставка ввода в строку заголовков - опасна

```
headers = f"From: {user_email}\r\nTo: {admin}\r\n\r\n"
```

```
full_message = headers + user_message
```

Любой `\r \n` в `user_email` создаст новый заголовок

Прямая вставка ввода в строку заголовков - опасна

```
async function sendFeedback(userEmail: string, userMessage: string) {  
  let transporter = nodemailer.createTransport({ /* config */ });  
  // БЕЗОПАСНО: Библиотека сама экранирует спецсимволы в полях 'from', 'to', 'subject'  
  let info = await transporter.sendMail({  
    from: userEmail, // Защищено nodemailer от CRLF  
    to: "admin@mysite.com",  
    subject: "New Feedback",  
    text: userMessage,  
  });
```

- Blacklisting - Попадание IP-адреса или домена в глобальные черные списки (Spamhaus, SURBL). Легитимная почта перестанет доходить до адресатов.
- Потеря репутации: Рассылка вредоносного контента от имени официального домена компании.
- Information Disclosure - Перехват конфиденциальных ответов через инъекцию заголовка Reply-To.

- Использование современных API - Отказ от ручной сборки MIME-сообщений в пользу встроенных классов (Nodemailer, EmailMessage).
- Валидация (Whitelisting) - Проверка email-адресов строгими регулярными выражениями (запрет пробелов и управляющих символов).
- Использование фиксированного системного адреса для отправки, а данных пользователя — только в поле Reply-To.

В ходе работы подтверждено, что отсутствие строгой фильтрации управляющих символов в веб-формах позволяет злоумышленнику полностью перехватить контроль над структурой SMTP-пакета. Это превращает стандартную функцию обратной связи в инструмент для несанкционированных действий.

Разработанные рекомендации и разобранные примеры кода могут быть использованы программистами и специалистами по информационной безопасности для проведения аудита существующих веб-приложений и проектирования защищенных систем уведомлений.